

Comment les distributions Linux s'adaptent-elles au «risque quantique» ?

Jérémy Viau-Trudel *Spécialiste DevSecOps*

André Gerges *Conseiller en recherche en cybersécurité et conformité*

Ikram Zahiri *Étudiante en génie logiciel*

Rencontre Linux Québec ■ mercredi 17 juin 17h

Québec - au Paccini de Ste-Foy

nouman/ty



01 - Plan de la présentation i

(avec sérieux et gravité)

Bonjour a tous, merci d'être là. Aujourd'hui, on parle de calcul quantique. Voici le plan.

D'abord, je vous démontre le théoreme de Shor au tableau. Y'est où le tableau ? Pas grave, on va s'arranger.

Puis, on Grover. On a besoin des 2 parce que Shor c'est pour l'asymétrie et Grover, le symétrie. Mais Grover est moyennement efficace...

Bref, après on va implémenter Shor avec Qiskit. Vous savez tous utiliser Qiskit, pas vrai ?

Et on va finir, avec une petite attaque faite à partir de l'ordinateur quantique d'IBM installe a Bromont. À plus de 200M\$ de taxes, il faut bien rentabiliser ça.

Sur quel

01 - Plan de la présentation ii

(Pause. On laisse le malaise monter.)

... Non. Je blague.

(Les lignes du faux plan se barrent une à une.)

Oui, le menace elle vient de cette possibilité qu'un jour on puisse être en mesure d'utiliser les ordinateurs quantique pour briser la cryptographie (principalement asymétrique).

Mais, si on fait bien notre travail, ça ne sera jamais exploitable.

Le but de cette présentation est justement de vous introduire aux notions d'encryption post-quantique.

Alors, nous allons couvrir 3 thématiques :

- Comment se décline la gestion des risques cyber pour les actifs cryptographiques

01 - Plan de la présentation iii

- Pourquoi ça devrait préoccuper les sysadmin linux et tous ceux qui ont la responsabilité d'assurer la sécurité d'infrastructures informatiques
- Et, le plus important, où doit-on apporter des changements à nos systèmes linux ?

Et finalement, Ikram qui est ici avec moi présentera un démo. On va regarder concrètement à quoi ça ressemble.

Je vous avertis tout de suite. Malgré le mot "quantique" c'est pas compliqué.

Plan de la présentation

- Démonstration de l'algorithme de **Shor** (*brise encryption asymétrique*)
- Démonstration de l'algorithme de **Grover** (*affaiblit encryption symétrique*)
- Implémentation naive de Shor avec la librairie de qbit **Qiskit**
- Lancer une attaque à partir de l'ordinateur quantique d'IBM à Bromont via le portail **PINQ2**

Plan de la présentation

- 1. Au-delà de fragilité cryptographique : la réponses de l'industrie
- 2. La cryptographie, au coeur de l'infrastructure Linux
- 3. Déploiement des nouvelles composantes cryptographiques
- 4. Démo : vérification manuelle et CBOM de `redhat/ubi10`

02 - Repenser la menace comme un risque i

Alors, de quoi parle-t-on, si ce n'est pas de quantique ? On parle de risque. Posez-vous la question, froidement : si la cryptographie à clé publique, celle qui protège à peu près tout, devenait cassable, on fait quoi ?

Ce qui rend ce sujet inconfortable, c'est qu'il touche au socle même de notre cybersécurité. Et face à ça, je vois deux erreurs symétriques. La première : négliger, parce qu'on n'y croit pas, parce que ça fait peur, ou parce que ce n'est jamais la priorité. La deuxième : se laisser submerger par le battage médiatique, au point de ne plus voir l'enjeu réel. Les deux mènent au même endroit : l'inaction.

Or le risque quantique n'est qu'un déclencheur. Le vrai enjeu, c'est de gérer notre cryptographie comme un actif et de vérifier notre chaîne d'approvisionnement logiciel. Et il y a une urgence concrète, le Harvest Now, Decrypt Later : on capte vos données chiffrées aujourd'hui pour les déchiffrer plus tard. L'exposition est donc déjà là. Bonne nouvelle : ce sont les mêmes pratiques

02 - Repenser la menace comme un risque ii

cyber et DevSecOps que vous connaissez déjà ; on relève simplement le niveau d'exigence sur ces actifs.

Alors posons la question qui va nous suivre toute la présentation : qu'arriverait-il si on n'agissait pas ?

Et la réponse, c'est que le monde a déjà commencé à agir. D'abord, il n'y a rien de nouveau dans la façon de s'y prendre : on gère ce risque avec les cadres qu'on utilise déjà, le NIST Cybersecurity Framework 2.0 et sa fonction de gouvernance, l'ISO 27005, le modèle FAIR pour le chiffrer en dollars.

Ensuite, la parade existe. En août 2024, le NIST a publié trois standards finaux : ML-KEM pour l'échange de clés, ML-DSA et SLH-DSA pour les signatures. Ce n'est plus de la recherche, c'est normalisé. L'Allemagne avec le BSI, la France avec l'ANSSI, l'Europe avec l'ETSI, le G7 dans une déclaration commune : tout le monde pousse dans le même sens. Et il y a un calendrier : on

02 - Repenser la menace comme un risque iii

déprécie les vieux algorithmes vers 2030, on les retire vers 2035. La question n'est donc plus « est-ce qu'il faut migrer », mais « quand et comment ».

Et chez nous ? Le Canada a tranché lui aussi. Le Centre canadien pour la cybersécurité s'appuie sur sa propre variante du cadre NIST et a publié une feuille de route de migration, l'ITSM.40.001, en vigueur depuis juin 2025. Surtout, ce ne sont pas que des recommandations : il y a des obligations contraignantes pour les systèmes du gouvernement fédéral et pour ses sous-traitants, jusqu'à l'inventaire cryptographique, le CBOM, qu'on vous montrera tout à l'heure. À côté de l'obligation, il y a aussi de l'accompagnement, avec un guide aux organisations, l'ITSAP.00.017, et des mesures d'aide.

Donc le cadre est posé, les standards sont là, les autorités ont agi. La seule question qui reste, c'est : et vous, en êtes-vous ?

Repenser la menace comme un risque

- Le « risque quantique » est un **déclencheur**, pas le sujet
- Il touche le **socle** de la cybersécurité : double risque, **négliger** ou se laisser **submerger** par le battage
- Les deux mènent au même endroit : l'**inaction**
- *Harvest Now, Decrypt Later* : l'exposition est **déjà présente**
- Le vrai enjeu : gérer la cryptographie comme un **actif**, vérifier sa chaîne d'approvisionnement
- Mêmes pratiques **cyber et DevSecOps**, niveau d'exigence relevé

C'est déjà normalisé

- Le risque se gère avec les **cadres existants** : NIST CSF 2.0, ISO 27005, FAIR
- Standards **NIST** (août 2024) : FIPS 203 **ML-KEM**, 204 **ML-DSA**, 205 **SLH-DSA**
- Relais internationaux : **BSI**, **ANSSI**, **ETSI** ; déclaration du **G7**
- Calendrier daté : dépréciation vers **2030**, retrait vers **2035**
- La question n'est plus « si » mais « **quand et comment** »

Et le Canada ?

- Le **Centre canadien pour la cybersécurité** s'appuie sur une variante du NIST CSF
- **Feuille de route** de migration ITSM.40.001 (en vigueur le 23 juin 2025)
- **Obligations contraignantes** pour le fédéral et ses sous-traitants, jusqu'au **CBOM**
- Guide aux organisations **ITSAP.00.017** et mesures d'**accompagnement**
- Et vous, **en êtes-vous ?**

04 - C'est déjà pris en charge, et vous ? i

(Ton qui s'ouvre. Interaction avec la salle.)

Justement, posons-la pour de vrai. Qu'est-ce qui arriverait si personne n'agissait ?

(Laisser deux ou trois reponses.)

Bonne nouvelle : on n'en est pas là, parce que le monde a déjà commence. La communauté internationale de cybersécurité a agi. Le NIST a publié ses standards post-quantiques en 2024 : ML-KEM pour l'échange de clés, ML-DSA et SLH-DSA pour les signatures. Les Européens suivent : le BSI allemand, l'ANSSI française, l'ETSI. Le G7 a même publié une déclaration commune.

Et le Canada n'est pas en reste, comme **regulateur**. Le Centre canadien pour la cybersécurité a publié une feuille de route de migration, entrée en vigueur en juin 2025, avec des **obligations contraignantes** : les systèmes du gouvernement doivent migrer toute leur cryptographie à clé

04 - C'est déjà pris en charge, et vous ? ii

publique. Il y a même un guide pour les organisations. Voilà comment les autres s'y prennent : c'est cadre, c'est balise.

(Pivot vers l'outil, ton concret.)

Et vous, alors ? Comment savoir où **vous** en êtes ? Il y a un outil tout simple, l'inégalité de Mosca. Prenez trois nombres. Un : combien d'années vos données doivent rester confidentielles. Deux : combien d'années il vous faut pour migrer votre cryptographie. Trois : combien d'années avant que l'ordinateur quantique arrive. Si vous additionnez les deux premiers et que ça dépasse le troisième, vous êtes **déjà** en retard.

Et la beauté de la chose, c'est que vous pouvez faire ce calcul ce soir, sur votre propre infrastructure. C'est ça que je veux vous donner : pas une frayeur, un outil.

(Temps. Regard aux décideurs.)

04 - C'est déjà pris en charge, et vous ? iii

Donc la question n'est plus de savoir si c'est sérieux. C'est : ou en êtes-vous, et est-ce que ce risque est couvert par **vos** processus de cybersécurité, **vos** veille stratégiques ?

C'est deja pris en charge, et vous ?

todo

05 - Linux, infrastructure strategique i

Maintenant, le coeur. Et on commence par une mise au point pour les decideurs.

On entend souvent les amateurs de Linux se plaindre que personne ne l'utilise. C'est vrai sur un seul terrain : le poste de travail, autour de 5 pour cent. Partout ailleurs, Linux **domine** : environ 60 pour cent du web, 90 pour cent du cloud public, 71 pour cent du mobile via Android, la totalite des supercalculateurs. Linux n'est pas un noyau de bricoleur. C'est une **infrastructure strategique, fondamentale et irremplacable**. Et une infrastructure, ca s'entretient. Donc ca se finance.

(Afficher les deux tableaux.)

Et l'important, c'est que la cryptographie ne joue pas le meme role selon l'usage. Voici nos six categories. A gauche, leur importance strategique. A droite, l'usage de la crypto et les defis propres a chacune. Un serveur d'entreprise, une image de conteneur, un routeur, un telephone : ce ne sont pas les memes contraintes.

05 - Linux, infrastructure strategique ii

(Declinaison du leitmotiv.)

Qu'arriverait-il si on laissait ce socle strategique sans entretien ? La premiere etape pour l'eviter, c'est simplement de comprendre ca : ou est la crypto, et ce qu'elle protege, selon l'usage.

Linux, infrastructure strategique

todo

06 - Le flux upstream vers downstream i

La bonne nouvelle, c'est que derriere la diversite des centaines de distributions, il n'y a qu'une **poignee de briques logicielles**. Les voici. Si vous savez ce qui tourne dans ces quelques composants, vous savez presque tout.

Et les ameliorations arrivent par un **flux** previsible, de l'amont vers l'aval. Deux choses decident de la vitesse : la **feuille de route** de l'editeur, et le **modele de publication**, rolling ou stable. Regardez ce deuxieme tableau : RHEL avance vite parce que son editeur est proactif, Arch parce qu'il est rolling, Debian plus lentement parce qu'il est prudent.

(Declinaison du leitmotiv, vers la communaute.)

Qu'arriverait-il si vos equipes ignoraient la feuille de route PQC de vos propres distributions ? Et voici la reponse facile : ca s'apprend. En gros, **une journee de formation** Linux-PQC permet a une equipe operationnelle de prendre en charge l'essentiel du risque, et surtout de savoir le **remonter** a l'equipe cyber.

06 - Le flux upstream vers downstream ii

(A la communauté.)

La question à vous poser en rentrant : est-ce que le couple feuille de route plus modèle de publication de vos distributions colle à vos besoins de protection des données ?

Le flux upstream vers downstream

todo

07 - Les briques de la crypto Linux, en détail i

Entrons dans la technique, c'est la partie la plus importante pour vous. Voici les briques, et depuis quelle version chacune fait du post-quantique.

Les deux moteurs, ce sont **OpenSSL** et **OpenSSH**. OpenSSL 3.5, sorti en avril 2025, apporte ML-KEM, ML-DSA et SLH-DSA nativement, et active l'échange de cles hybride par défaut en TLS. OpenSSH fait du post-quantique par défaut depuis la version 10. A cote, GnuTLS, NSS et le runtime Go ont le meme échange hybride ; Go l'active par défaut depuis la 1.24, ce qui couvre tous les outils cloud-native écrits en Go. Pour l'embarque, wolfSSL est déjà prêt et valide ; mbedTLS, pas encore. Et le noyau a ses propres chantiers en cours.

(Declinaison du leitmotiv.)

Qu'arriverait-il si vous laissiez ces briques sur une version pre-PQC ? A l'inverse, passer a OpenSSL 3.5 et OpenSSH 10, c'est déjà l'essentiel du chemin. La posture d'une distribution, c'est d'abord la version de ces briques qu'elle embarque.

Les briques de la crypto Linux, en detail

todo

08 - Carte de maturite PQC par categorie i

Si on prend de la hauteur, voici la carte de qui en est ou.

Le meneur, c'est Red Hat. RHEL active le post-quantique par default et, fait unique, **signe ses paquets** avec une signature post-quantique. Les distributions en rolling, Fedora, Tumbleweed, Arch, suivent tres tot. Ubuntu et Debian arrivent au rythme de leurs versions stables. Le conteneur est plutot mur, surtout les images fraiches et signees comme Wolfi. Le mobile avance sur le web mais traine cote plateforme. Et l'IoT contraint, c'est le plus en retard.

(Declinaison du leitmotiv, breve.)

Qu'arriverait-il si vous misiez, sans le savoir, sur une distribution a la traine ? Cette carte vous evite la mauvaise surprise.

Carte de maturite PQC par categorie

todo

09 - Demo : verifier le PQC soi-meme i

(Bascule vers la demonstration, preparee separement.)

Et maintenant, le plus utile. Je ne veux pas que vous repartiez avec juste une carte ; je veux que vous repartiez avec une **competence**.

La premiere etape de toute migration, ce n'est pas d'installer du post-quantique. C'est de savoir **ou** vous avez de la cryptographie. On appelle ca un CBOM, un inventaire cryptographique.

(Enonce du leitmotiv, version forte.)

Parce que, honnêtement : qu'arriverait-il si vous ne saviez meme pas ou se trouve votre cryptographie ? On ne migre pas ce qu'on ne voit pas. Alors voici comment la rendre visible, et vous allez voir, c'est a votre portee.

(Lancer la demo preparee. Commenter le resultat sur une ou deux images contrastees.)

09 - Demo : verifier le PQC soi-meme ii

Voila. Vous saurez refaire ca en rentrant chez vous. Et c'est exactement le point de depart de la crypto-agilite : un inventaire a jour, qu'on rescanne apres chaque changement.

Demo : verifier le PQC soi-meme

todo

10 - Conclusion et appel i

On resume en trois mots. **Recadrer** : le quantique n'est qu'un declencheur, le vrai sujet est la gestion de la cryptographie dans Linux. **Responsabiliser** : ni deni, ni panique ; l'enjeu est cadre, le monde et le Canada ont agi, a vous de jouer. **Outils** : vous repartez avec une competence concrete, l'inventaire cryptographique.

(Rappel explicite du leitmotiv.)

Vous avez remarque : a chaque etape, j'ai pose la meme question, qu'arriverait-il si on n'agissait pas ? Et a chaque fois, il y avait un voici comment. C'est ca, le message : ces choses-la se font.

(Temps. Regard a la salle, puis aux decideurs.)

Pour les organisations dans la salle : pour vous, c'est du travail ; pour nous, c'est le metier. Ce qu'on vient de montrer est directement applicable chez vous. Nous sommes les gens du PQC au Quebec. Venez nous parler. Merci.

Conclusion et appel

todo

Merci de prendre au sérieux la ***menace quantique*** !

Questions ?



github.com/noumanity/pqc-linux